

HOSPITAL CENTRAL

Rede de UPAs — Sistema Integrado de Saúde

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

PSI — Versão 1.0

Campo	Informação
Projeto	Política de Segurança da Informação
Disciplina	Projeto de Infraestrutura de Redes
Etapas	4 — Mecanismos de Segurança da Informação
Integrantes	Ítalo Rangel Penaforte, João de Sousa Lourenco, Rodrigo Cattoi, Rodrigo Lima, Ryann Parreira
Professor	Alexandre Teixeira
Data	Junho de 2026

Campo	Informação
Documento	Política de Segurança da Informação
Versão	1.0
Classificação	Interno — Uso Restrito
Data de Emissão	Junho de 2025
Responsável	Departamento de Tecnologia da Informação
Aprovado por	Diretoria do Hospital Central

1. Introdução

O Hospital Central, juntamente com sua rede de Unidades de Pronto Atendimento (UPAs) filiais, reconhece que a informação é um dos ativos mais valiosos da organização. No contexto da saúde, a proteção de dados é ainda mais crítica, uma vez que envolve informações sensíveis de pacientes, cujo vazamento ou uso indevido pode causar danos irreparáveis à privacidade e à integridade das pessoas atendidas.

Esta Política de Segurança da Informação (PSI) estabelece os princípios, diretrizes e responsabilidades que devem ser seguidos por todos os colaboradores, prestadores de serviço e parceiros que, de qualquer forma, produzam, acessem, armazenem, transmitam ou descartam informações pertencentes ao Hospital Central e suas unidades.

A PSI está em conformidade com a Lei Geral de Proteção de Dados Pessoais (LGPD — Lei nº 13.709/2018), com as melhores práticas da norma ABNT NBR ISO/IEC 27001 e com os regulamentos aplicáveis ao setor de saúde no Brasil.

1.1 Objetivos

- Proteger os dados pessoais e sensíveis dos pacientes atendidos na rede
- Garantir a confidencialidade, integridade e disponibilidade das informações
- Estabelecer responsabilidades claras sobre o uso e guarda das informações
- Prevenir incidentes de segurança e definir procedimentos de resposta
- Assegurar conformidade com a LGPD e demais legislações aplicáveis

2. Abrangência

Esta política se aplica a todos os ambientes físicos e digitais do Hospital Central e de suas UPAs filiais, abrangendo:

- Todos os colaboradores efetivos, estagiários e prestadores de serviço
- Sistemas de informação internos (prontuário eletrônico, sistema de agendamento, ERP hospitalar)
- Infraestrutura de TI (servidores, estações de trabalho, dispositivos móveis, redes)
- Comunicações eletrônicas (e-mail corporativo, aplicativos de mensagem autorizados)
- Dados físicos (impressos, fichas, documentos em papel)
- Fornecedores e parceiros com acesso a sistemas ou dados da organização

O não cumprimento desta política por qualquer pessoa sujeita a ela poderá resultar em medidas disciplinares, incluindo desligamento e responsabilização civil e criminal, conforme a gravidade do incidente.

3. Classificação das Informações

Toda informação tratada pelo Hospital Central deve ser classificada de acordo com o grau de sensibilidade e o impacto que sua exposição não autorizada poderia causar. A classificação determina os controles de segurança aplicáveis.

Classificação	Descrição	Exemplos
Confidencial	Dados de alto impacto. Acesso restrito a pessoas explicitamente autorizadas.	Prontuários, diagnósticos, dados de saúde do paciente, senhas
Restrito	Uso interno. Disponível apenas para setores ou funções específicas.	Relatórios financeiros, escalas de trabalho, contratos
Interno	Uso geral por todos os colaboradores. Sem impacto crítico se divulgado.	Comunicados internos, cardápio do refeitório, avisos gerais
Público	Informações divulgadas ao público sem restrições.	Site institucional, endereços das UPAs, horários de funcionamento

4. Controle de Acesso

O acesso aos sistemas e informações do Hospital Central é concedido com base no princípio do menor privilégio, ou seja, cada colaborador tem acesso somente às informações estritamente necessárias ao desempenho de suas funções.

4.1 Perfis de Acesso

Perfil	Permissões
Médico	Acesso completo aos prontuários dos pacientes sob seus cuidados. Pode registrar diagnósticos, prescrições e evoluções.
Enfermeiro/Técnico	Acesso às informações de cuidados de enfermagem. Não pode alterar diagnósticos ou prescrições médicas.
Recepcionista	Acesso a dados cadastrais (nome, CPF, endereço) e agendamentos. Sem acesso a dados clínicos.
Gestor de UPA	Acesso a relatórios gerenciais e operacionais da sua unidade. Sem acesso a dados clínicos individuais.
Administrador de TI	Acesso à infraestrutura de TI. Não pode acessar dados clínicos sem autorização expressa da diretoria.

4.2 Regras de Controle de Acesso

- Todo acesso deve ser precedido de autenticação com credenciais individuais e intransferíveis
- É vedado o compartilhamento de credenciais de acesso entre colaboradores
- O acesso deve ser revogado imediatamente após desligamento ou mudança de função
- Acessos privilegiados (administradores) devem ser revisados trimestralmente
- O acesso remoto às UPAs deve ser realizado exclusivamente por meio de VPN corporativa

5. Gestão de Senhas

As senhas são o principal mecanismo de autenticação dos sistemas do Hospital Central. Sua gestão adequada é essencial para a segurança das informações.

5.1 Requisitos de Senha

- Comprimento mínimo de 10 caracteres
- Combinação obrigatória de letras maiúsculas, minúsculas, números e caracteres especiais
- Proibido o uso de informações pessoais (nome, data de nascimento, CPF)
- Proibido o uso de sequências óbvias (123456, abcdef, qwerty)
- Troca obrigatória a cada 90 dias
- Não é permitido reutilizar as últimas 5 senhas

5.2 Regras de Uso

- Senhas não devem ser anotadas em papéis ou armazenadas em arquivos não criptografados
- Em caso de suspeita de comprometimento, a senha deve ser trocada imediatamente e o incidente reportado ao TI
- Bloqueio automático da conta após 5 tentativas de login inválidas
- O desbloqueio deve ser solicitado ao setor de TI mediante verificação de identidade

6. Uso Aceitável dos Recursos de TI

Os recursos de tecnologia da informação do Hospital Central — computadores, redes, sistemas, e-mails e dispositivos móveis — são fornecidos exclusivamente para fins profissionais e devem ser utilizados de acordo com as diretrizes desta política.

6.1 Condutas Permitidas

- Uso dos sistemas para atividades relacionadas às funções do colaborador
- Acesso a conteúdos relacionados à saúde, medicina e gestão hospitalar
- Uso do e-mail corporativo para comunicações profissionais
- Armazenamento de arquivos de trabalho nas pastas corporativas designadas

6.2 Condutas Proibidas

- Instalação de softwares não autorizados pelo setor de TI
- Uso de dispositivos de armazenamento externos (pen drives, HDs externos) não homologados
- Acesso a sites de entretenimento, redes sociais pessoais ou conteúdo impróprio durante o expediente
- Envio de dados de pacientes por e-mail pessoal ou aplicativos de mensagem não autorizados
- Conexão à rede Wi-Fi pessoal ou hotspots móveis com equipamentos corporativos
- Fotografar telas ou documentos com dados de pacientes
- Tentativa de acesso a sistemas ou dados além das permissões atribuídas

7. Dispositivos e Acesso Remoto

7.1 Dispositivos Corporativos

- Equipamentos de TI são patrimônio do Hospital Central e devem ser utilizados somente para fins profissionais
- A tela deve ser bloqueada sempre que o colaborador se afastar do posto de trabalho
- Equipamentos não devem ser retirados das instalações sem autorização formal
- Em caso de perda ou roubo, o TI deve ser notificado imediatamente

7.2 Acesso Remoto e entre UPAs

- O acesso remoto aos sistemas do hospital somente é autorizado via VPN corporativa
- A comunicação entre o Hospital Central e as UPAs deve ser realizada por canais seguros e criptografados
- Dispositivos pessoais (BYOD) não são autorizados para acesso a sistemas com dados confidenciais
- Sessões remotas devem ser encerradas ao término do uso

8. Backup e Continuidade dos Serviços

A disponibilidade das informações é essencial para a continuidade dos serviços de saúde. O Hospital Central adota as seguintes diretrizes para garantir a recuperação de dados em caso de falha ou incidente:

- Backups automáticos diários de todos os bancos de dados críticos (prontuários, sistemas de gestão)
- Backups semanais armazenados em ambiente de nuvem separado da infraestrutura principal
- Teste de restauração dos backups realizado mensalmente pelo setor de TI
- Tempo máximo de recuperação (RTO) de 4 horas para sistemas críticos
- Plano de Continuidade de Negócios (PCN) revisado anualmente
- Em caso de falha total de sistema, ativar protocolo de registro manual até a restauração

9. Gestão de Incidentes de Segurança

Um incidente de segurança é qualquer evento que comprometa ou ameace a confidencialidade, integridade ou disponibilidade das informações do Hospital Central.

9.1 Exemplos de Incidentes

- Acesso não autorizado a dados de pacientes
- Perda ou roubo de dispositivos com informações corporativas
- Suspeita de infecção por malware ou ransomware
- Vazamento de dados de pacientes
- Tentativas de phishing ou engenharia social

9.2 Procedimento de Resposta

1. Identificar e documentar o incidente imediatamente
2. Notificar o setor de TI pelo canal oficial (ramal ou e-mail de incidentes)
3. Preservar evidências — não desligar equipamentos sem orientação do TI
4. O TI realiza análise, contenção e erradicação do incidente
5. Registro formal do incidente no sistema de gestão de segurança
6. Comunicação à ANPD se o incidente envolver vazamento de dados pessoais (obrigação LGPD)
7. Elaboração de relatório pós-incidente com lições aprendidas

10. Conformidade com a LGPD

O Hospital Central é um operador e controlador de dados pessoais sensíveis, conforme definido pela Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018). Dados de saúde são considerados dados sensíveis pela legislação e exigem proteção reforçada.

10.1 Princípios Aplicados

- Finalidade: dados coletados somente para prestação de serviços de saúde
- Necessidade: coleta limitada ao mínimo necessário para o atendimento
- Transparência: pacientes informados sobre como seus dados são utilizados
- Segurança: medidas técnicas e administrativas para proteção dos dados
- Prevenção: adoção proativa de práticas para evitar incidentes

10.2 Direitos dos Titulares (Pacientes)

- Acesso aos seus dados pessoais armazenados pelo hospital
- Correção de dados incompletos, inexatos ou desatualizados
- Portabilidade dos dados para outro profissional ou serviço de saúde
- Informação sobre compartilhamento de dados com terceiros
- Revogação de consentimento, quando aplicável

Solicitações relacionadas aos direitos dos titulares devem ser encaminhadas ao Encarregado de Dados (DPO) do Hospital Central, no prazo máximo de resposta de 15 dias úteis.

11. Penalidades pelo Descumprimento

O descumprimento das diretrizes estabelecidas nesta política sujeitará o colaborador infrator às seguintes medidas, de acordo com a gravidade e a reincidência da infração:

- Advertência verbal ou escrita
- Suspensão temporária de acesso aos sistemas
- Suspensão remunerada ou não remunerada
- Desligamento por justa causa
- Responsabilização civil e criminal, conforme legislação vigente

Incidentes que resultem em vazamento de dados de pacientes podem ainda acarretar penalidades administrativas impostas pela Autoridade Nacional de Proteção de Dados (ANPD), conforme previsto na LGPD.

12. Vigência e Revisão

Esta Política de Segurança da Informação entra em vigor na data de sua aprovação pela Diretoria do Hospital Central e tem prazo de vigência indeterminado, devendo ser revisada:

- Anualmente, de forma ordinária
- Após a ocorrência de incidentes de segurança relevantes
- Mediante alterações significativas na legislação aplicável
- Quando houver mudanças relevantes na infraestrutura de TI ou nos processos do hospital

Todos os colaboradores devem ser informados sobre as atualizações desta política, sendo obrigatório o aceite formal a cada nova versão aprovada.